BTEUP EXAM NOTES | ENGLISH EDITION

Information Security

Unit 5: Standards, IT Act, Audit, Policies, Disaster Recovery and BCP

About these notes

Part A explains every topic in very simple English with real-life examples, so a beginner can understand it from zero.
Part B gives important exam questions with full 5-mark model answers, ready to write in the exam.
At the end: quick revision sheet, common mistakes, and a self-test.

Syllabus covered (Unit 5)

Introduction to Security Standards: ISO 27001, Indian IT Act, IPR Laws; Security Audit procedures; Developing Security Policies; Disaster Recovery, Business Continuity Planning.

Unit Overview and Contents

Simple idea: Technology alone cannot make an organization secure. It also needs **rules** (standards and policies), **laws** (IT Act, IPR), **checking** (security audit) and a **backup plan** for bad days (disaster recovery and business continuity). This unit is the **management and legal side** of security.

Topic	Exam importance	Where in notes
ISO 27001	Very High	Part A: Topic 1 | Part B: Q1, Q2
Indian IT Act	Very High	Part A: Topic 2 | Part B: Q3, Q4
IPR Laws	Very High	Part A: Topic 3 | Part B: Q5, Q6
Security Audit procedure	Very High	Part A: Topic 4 | Part B: Q7, Q8
Developing Security Policies	High	Part A: Topic 5 | Part B: Q9, Q10
Disaster Recovery, BCP	Very High	Part A: Topic 6 | Part B: Q11, Q12

Contents

Part A: Easy Explanation	Part B: Important Questions with Answers
Topic 1: Security Standards, ISO 27001 Topic 2: Indian IT Act Topic 3: IPR Laws Topic 4: Security Audit Topic 5: Security Policies Topic 6: DR and BCP	Q1 ISO 27001 and ISMS (Very Likely) Q2 Annex A controls and certification (Likely) Q3 IT Act 2000 features (Very Likely) Q4 Cyber offences and punishments (Very Likely) Q5 IPR and its types (Very Likely) Q6 Copyright vs Patent vs Trademark (Likely) Q7 Security audit procedure (Very Likely) Q8 Types of security audit (Possible) Q9 Developing a security policy (Very Likely) Q10 Types of security policies (Likely) Q11 Business Continuity Planning (Very Likely) Q12 Disaster Recovery, RTO, RPO, BCP vs DR (Very Likely)

How to study this unit (suggested time: 1 day)

1) Read Part A once to understand. 2) Read Part B answers and copy each answer on paper with the diagram. 3) Revise using the Quick Revision Sheet. 4) Attempt the Self-Test without looking.

PART A: Easy Explanation (Simple English)

Topic 1: Security Standards and ISO 27001

Real-life example

A standard is like a **recipe followed by all good restaurants**. If a restaurant follows the recipe and an inspector confirms it, customers trust it. A security standard does the same for information security.

Definition

A **security standard** is a documented set of best practices and requirements that organizations follow to protect information in a consistent, proven way.

Standard / Law	Purpose
ISO/IEC 27001	International standard for an Information Security Management System (ISMS)
ISO/IEC 27002	Guidelines (code of practice) for the security controls
ISO 22301	Business Continuity Management System
PCI DSS	Security of payment card data
NIST Cybersecurity Framework	US framework: Identify, Protect, Detect, Respond, Recover

ISO/IEC 27001

Definition

ISO/IEC 27001 is the international standard that specifies the requirements to **establish, implement, maintain and continually improve an Information Security Management System (ISMS)**. The current edition is **ISO/IEC 27001:2022**.

- **ISMS** is a systematic approach to manage sensitive information by managing people, processes and technology, based on **risk assessment**.
- It protects the **CIA triad**: Confidentiality, Integrity, Availability.
- It follows the **PDCA** cycle: Plan, Do, Check, Act.
- **Clauses 4 to 10** contain the requirements: context, leadership, planning, support, operation, performance evaluation, improvement.
- **Annex A** lists **93 controls** in four themes: Organizational (37), People (8), Physical (14), Technological (34). The older 2013 edition had 114 controls in 14 domains.
- The organization selects the controls it needs and records them in the **Statement of Applicability (SoA)**.

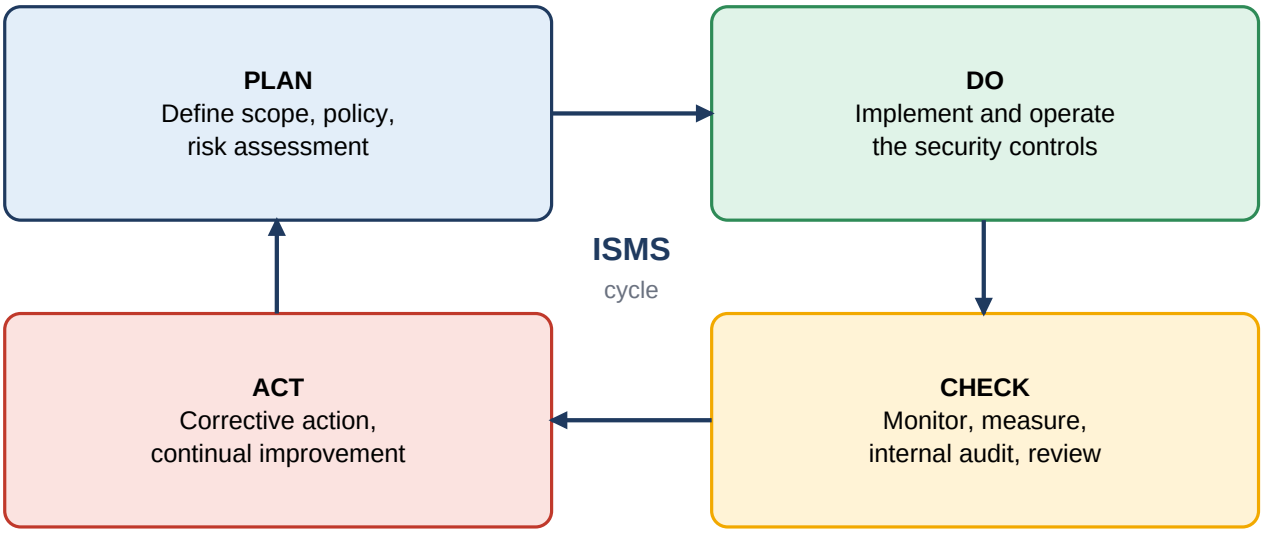


Figure 1: PDCA cycle of ISMS (ISO 27001)

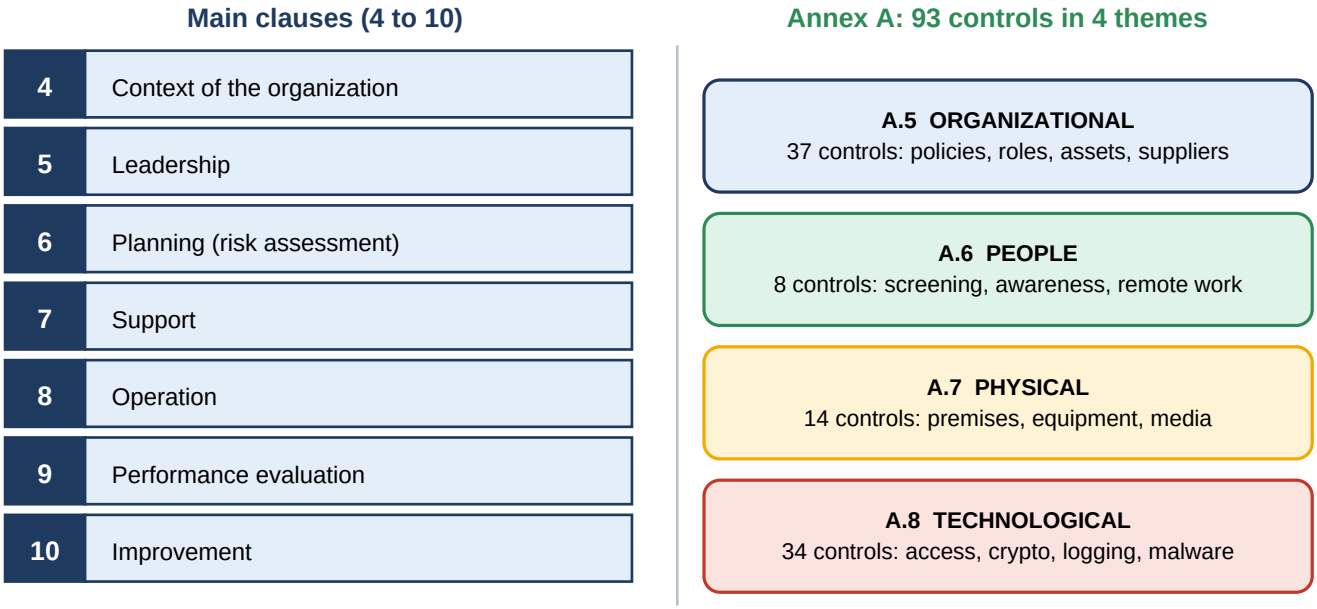


Figure 2: ISO 27001:2022 structure: clauses and Annex A

Certification and benefits

- **Stage 1 audit:** the auditor reviews documents. **Stage 2 audit:** the auditor checks that controls are really implemented.
- A certification body issues a certificate valid for **3 years**, with **yearly surveillance audits**, then recertification.
- **Benefits:** customer trust, legal and regulatory compliance, fewer security incidents, better risk management, competitive advantage.

Topic 2: Indian IT Act

Real-life example

Traffic rules punish people who drive wrongly on roads. In the same way, the IT Act punishes people who misuse computers and the Internet, and it also gives **legal value to digital documents and signatures**.

Definition

The **Information Technology Act, 2000** is the main Indian law for **cyber crime and electronic commerce**. It was substantially amended by the **IT (Amendment) Act, 2008**.

Main objectives and features

- Gives **legal recognition to electronic records and digital signatures** (Sections 4, 5), so e-contracts and e-filing are valid.
- Promotes **e-commerce and e-governance**.
- Defines **cyber offences** and their punishments (Sections 65 to 75).
- Creates **Certifying Authorities** and a **Controller** for digital signature certificates.
- **CERT-In** (Section 70B) is the national agency for cyber incident response.
- Applies to the whole of India and also to offences committed outside India that involve a computer in India.

Important sections and punishments

Section	Offence	Punishment
43	Unauthorized access, data theft, virus, damage to computer	Compensation to the victim (civil)
65	Tampering with computer source documents	Up to 3 years or fine up to Rs 2 lakh, or both
66	Computer-related offences (hacking: dishonest or fraudulent act under Sec 43)	Up to 3 years or fine up to Rs 5 lakh, or both
66B	Dishonestly receiving a stolen computer or device	Up to 3 years or fine up to Rs 1 lakh, or both
66C	Identity theft (using another person's password, e-signature)	Up to 3 years and fine up to Rs 1 lakh
66D	Cheating by personation using a computer resource	Up to 3 years and fine up to Rs 1 lakh
66E	Violation of privacy (capturing private images)	Up to 3 years or fine up to Rs 2 lakh, or both
66F	Cyber terrorism	Imprisonment up to life
67	Publishing or transmitting obscene material	First conviction: up to 3 years and fine up to Rs 5 lakh. Repeat: up to 5 years and Rs 10 lakh
67A / 67B	Sexually explicit material / child sexual abuse material	First conviction: up to 5 years and fine up to Rs 10 lakh (more on repeat)
72	Breach of confidentiality and privacy	Up to 2 years or fine up to Rs 1 lakh, or both

Good to know

Section 66A (sending offensive messages) was **struck down by the Supreme Court in 2015** (Shreya Singhal case), so it is no longer valid. Section 43: compensation was earlier limited to Rs 1 crore; the 2008 amendment removed the ceiling (some textbooks still say Rs 1 crore). The new **Digital Personal Data Protection Act, 2023** adds a separate law on personal data. Its Rules were notified in November 2025 and its main duties start in phases, mainly from May 2027.

Topic 3: IPR Laws (Intellectual Property Rights)

Real-life example

If you build a house, it is your property and others cannot take it. In the same way, if you create a **song, software, invention or brand**, it is your **intellectual property**, and the law stops others from copying it.

Definition

IPR are legal rights given to a person over the **creations of the mind** (inventions, literary and artistic works, designs, symbols, names), allowing the owner to control and earn from them.

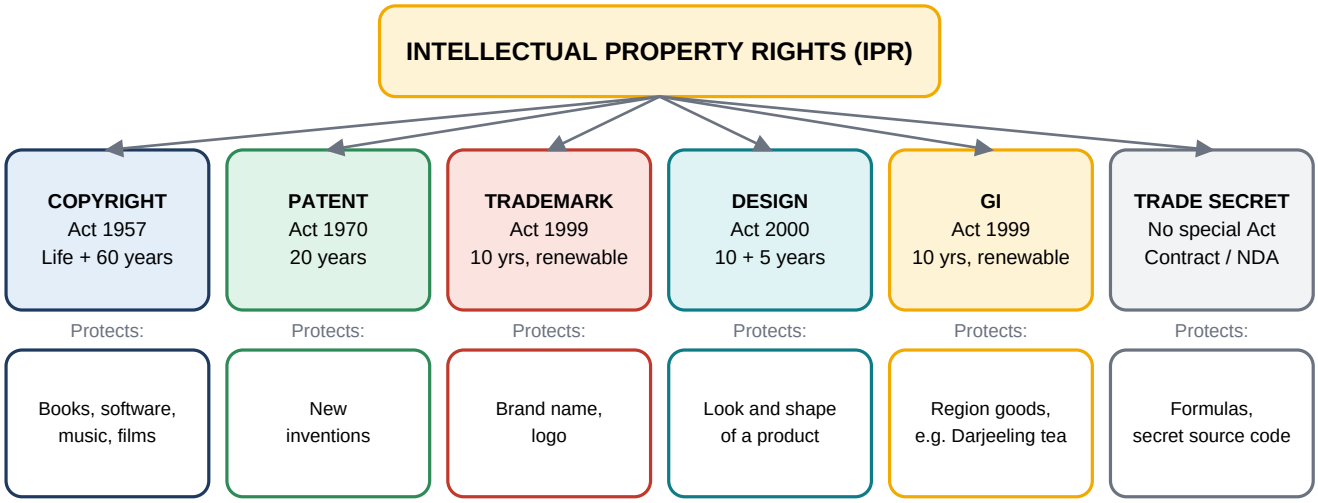


Figure 3: Types of IPR in India

IPR	Indian law	Protects	Duration
Copyright	Copyright Act, 1957	Books, music, films, **software**, art	Author's life + 60 years
Patent	Patents Act, 1970	New, useful inventions	20 years
Trademark	Trade Marks Act, 1999	Brand name, logo, slogan	10 years, renewable
Design	Designs Act, 2000	Shape, pattern, look of a product	10 years + 5 extension
Geographical Indication (GI)	GI Act, 1999	Goods linked to a region (Darjeeling tea, Banarasi saree)	10 years, renewable
Trade secret	No separate Act	Secret formulas, business information	As long as it stays secret

IPR and software

- **Software is protected by copyright** as a literary work. Copying or selling pirated software is **software piracy**, punishable under Section 63 of the Copyright Act (imprisonment from 6 months to 3 years and fine).
- A **computer program per se** cannot be patented in India (Section 3(k) of the Patents Act), but a technical invention that uses software may be.
- Open-source licences (GPL, MIT) give users rights to use and modify code under conditions.
- **Relation to security:** IPR laws protect source code, designs and data from theft, and the IT Act punishes cyber theft of such property.

Topic 4: Security Audit Procedures

Real-life example

A security audit is like a **health check-up**. The doctor takes your history, runs tests, finds problems and writes a report with medicines. Later you go for a follow-up. An audit does the same for your IT systems.

Definition

A **security audit** is a systematic, independent evaluation of an organization's information systems, policies and controls to check whether they meet security policy, standards and laws, and to find weaknesses.

Steps of a security audit

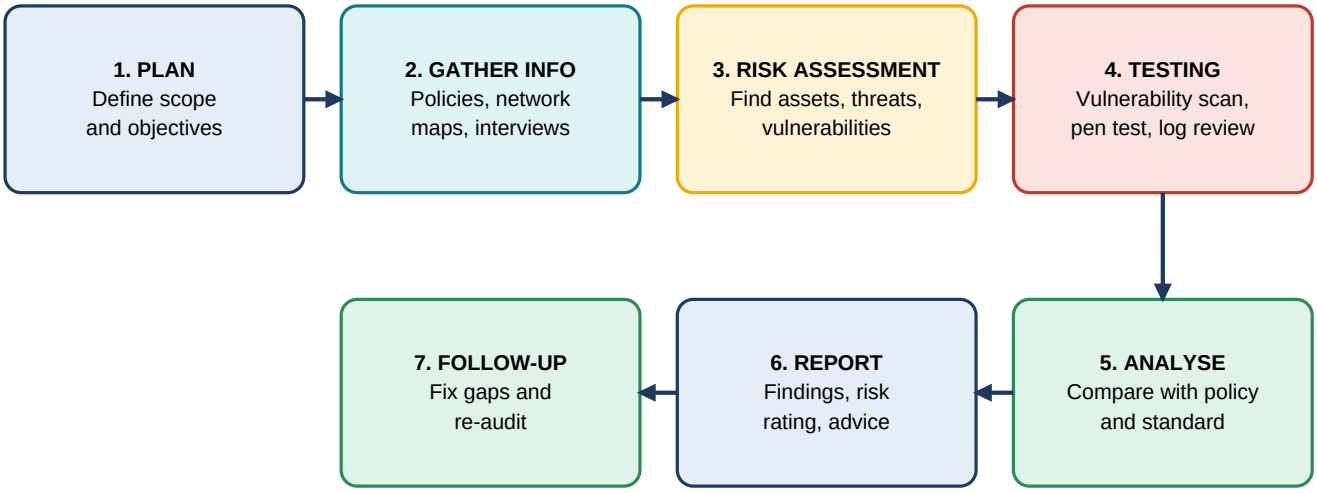


Figure 4: Security audit procedure

- **1. Planning and scoping:** decide objectives, scope (which systems), standards to check, team and schedule.
- **2. Information gathering:** collect policies, network diagrams, asset list; interview staff; review past audits.
- **3. Risk assessment:** identify assets, threats, vulnerabilities and their impact.
- **4. Testing:** vulnerability scanning, penetration testing, configuration and log review, physical inspection.
- **5. Analysis:** compare results with the policy and standard; rate each finding by risk.
- **6. Reporting:** prepare a report with findings, risk ratings and recommendations; present to management.
- **7. Follow-up:** fix the gaps (remediation) and re-audit to confirm.

Types and areas of audit

Type	Meaning
Internal audit	Done by the organization's own staff
External audit	Done by an independent third party / certification body
Compliance audit	Checks compliance with a standard or law (ISO 27001, IT Act)
Technical audit	Tests systems, networks and applications (scans, pen tests)

- **Areas checked:** physical security, access control and passwords, network and firewall, operating systems, applications, backups, logs, policies and staff awareness.
- **Tools:** Nmap, Nessus, OpenVAS (scanners), Wireshark, Metasploit (testing), log analyzers.

Topic 5: Developing Security Policies

Real-life example

A school has rules: wear uniform, no mobile phones in class. Everyone knows what is allowed and what happens if the rule is broken. A security policy is the **rulebook of an organization for protecting information**.

Definition

A **security policy** is a formal, written document, approved by management, that states **what must be protected, who is responsible, and what rules everyone must follow** to keep information secure.

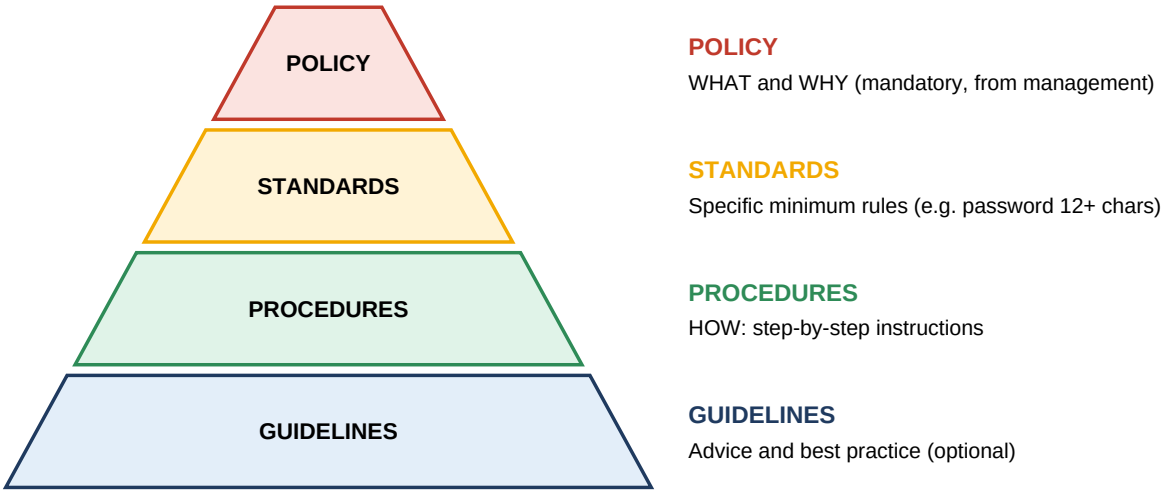


Figure 5: Policy, standards, procedures and guidelines

Steps to develop a security policy

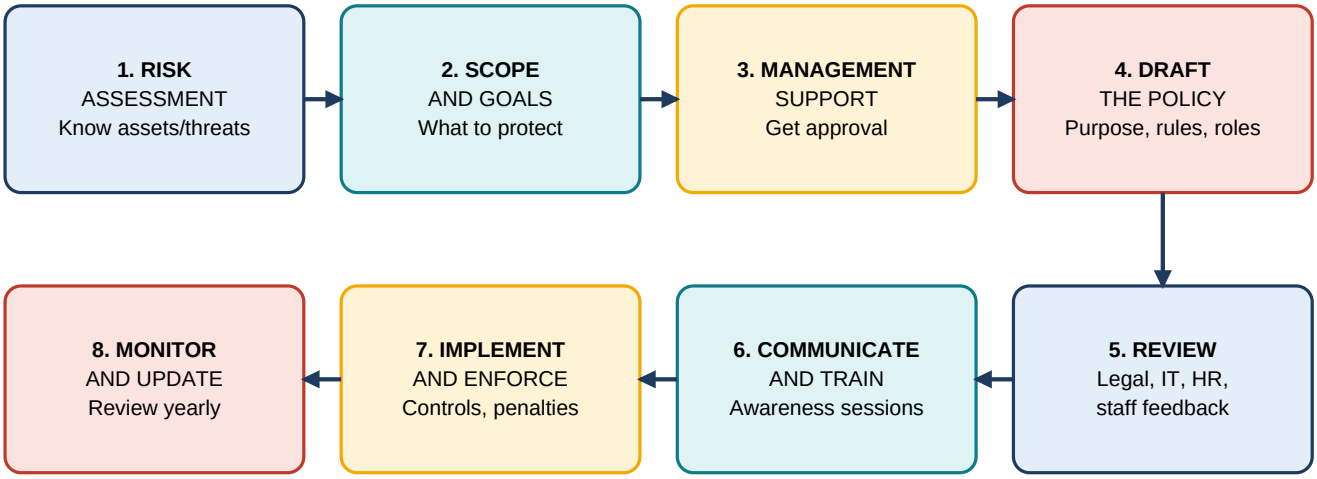


Figure 6: Developing a security policy

- **1. Risk assessment:** know your assets, threats and legal needs.
- **2. Scope and goals:** decide what the policy covers and what it must achieve.
- **3. Management support:** top management must approve and back the policy.
- **4. Draft:** write purpose, scope, roles and responsibilities, rules, penalties for violation.
- **5. Review:** get feedback from IT, legal, HR and users.
- **6. Communicate and train:** every employee must read and understand it.
- **7. Implement and enforce:** apply technical controls and discipline for violations.

- **8. Monitor and update:** review at least yearly or after incidents.

Qualities of a good policy

- Clear and simple, realistic and enforceable, approved by management, flexible, regularly reviewed, and aligned with laws and standards such as ISO 27001.

Common types of security policies

Policy	What it covers
Acceptable Use Policy (AUP)	How employees may use computers, email and Internet
Password policy	Length, complexity, change period, no sharing
Access control policy	Who can access what (least privilege)
Email and Internet policy	Safe email use, phishing, personal use limits
Backup and retention policy	What is backed up, how often, how long kept
Incident response policy	How to report and handle security incidents
Remote access / BYOD policy	Use of VPN and personal devices
Physical security policy	Entry control, visitors, equipment protection

Topic 6: Disaster Recovery and Business Continuity Planning

Real-life example

Imagine a shop floods during heavy rain. **Business Continuity** is the plan to keep selling (move to another shop, inform customers, pay staff). **Disaster Recovery** is the plan to repair the computers and get the records back.

Definition

Business Continuity Plan (BCP) is a plan that ensures **critical business functions continue** during and after a disaster or disruption. **Disaster Recovery Plan (DRP)** is the part of it that focuses on **restoring IT systems, data and network** after a disaster.

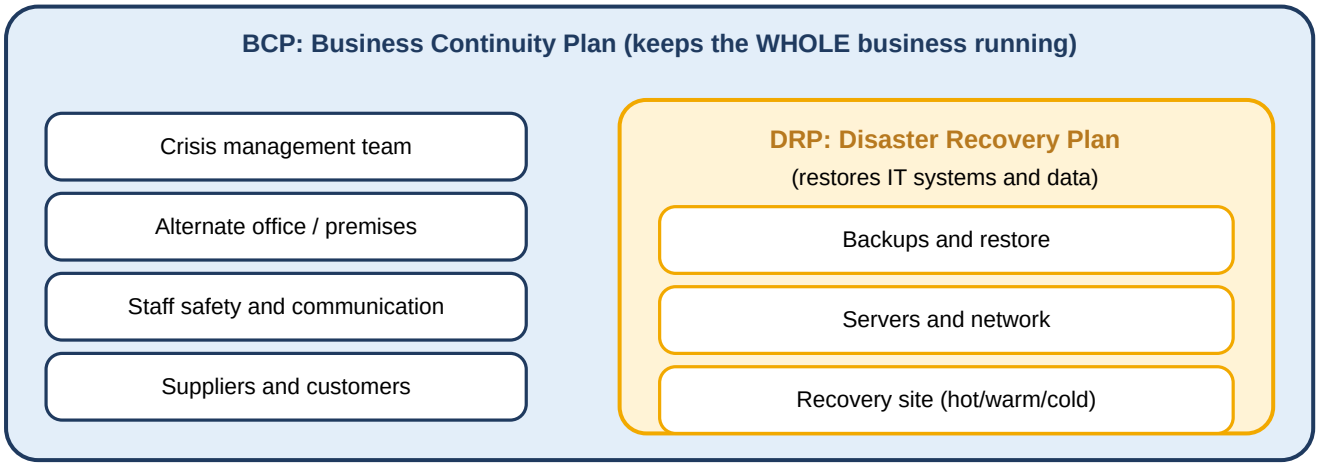


Figure 7: BCP and DRP

Disasters can be

- **Natural:** flood, earthquake, fire, storm. **Technical:** hardware failure, power cut, software bug, ransomware, cyber attack. **Human:** mistakes, sabotage, theft, strike.

Steps of Business Continuity Planning

- **1. Project initiation:** get management approval, form the team, define scope.
- **2. Business Impact Analysis (BIA):** find critical processes, how long they can be down, and the loss from downtime.
- **3. Risk assessment:** identify threats and likelihood.
- **4. Strategy:** choose recovery strategies (backups, alternate site, spare equipment).
- **5. Plan development:** write the BCP and DRP with roles, contact lists and step-by-step actions.
- **6. Testing and training:** walkthroughs, simulations, full drills; train staff.
- **7. Maintenance:** review and update the plan regularly.

Important terms: RTO, RPO, MTD

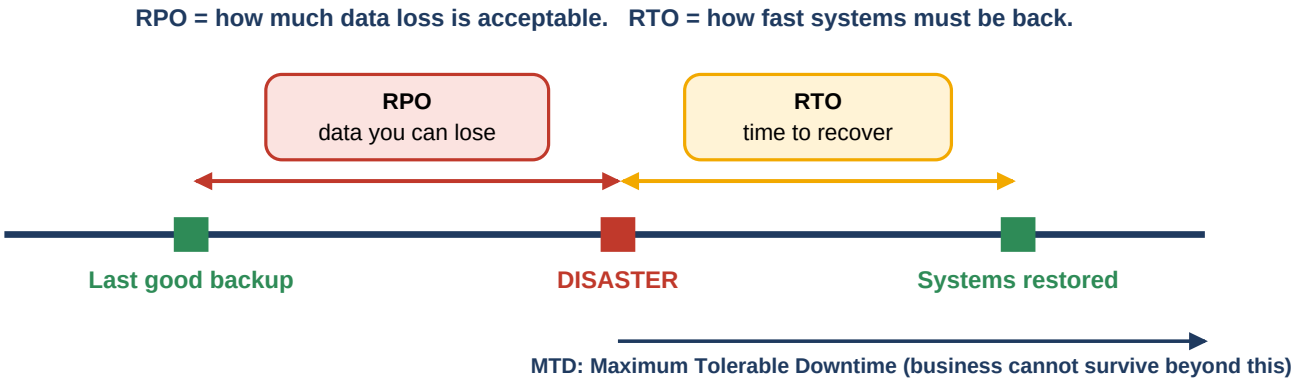


Figure 8: RPO, RTO and MTD

- **RPO (Recovery Point Objective):** the maximum data loss acceptable, measured in time. If RPO is 1 hour, backups must be taken at least every hour.
- **RTO (Recovery Time Objective):** the maximum time allowed to restore a system after a disaster.
- **MTD (Maximum Tolerable Downtime):** the longest outage the business can survive. RTO must be less than MTD.

Disaster recovery strategies

- **Backups: Full** (copy everything), **Incremental** (only changes since the last backup of any type), **Differential** (changes since the last full backup).
- **3-2-1 rule:** keep 3 copies of data, on 2 different media, with 1 copy off-site.
- **Recovery sites:** hot, warm and cold sites (see figure).
- **Other:** data replication, cloud backup, UPS and generator, RAID, spare hardware.



Figure 9: Hot, warm and cold recovery sites

Point	BCP	DRP
Focus	Whole business operations	IT systems and data
Scope	Wider (people, premises, process)	Narrower (technology)
Aim	Keep business running	Restore IT after disaster
Timing	Before, during and after	Mainly after the disaster

PART B: Important Questions with Model Answers (English)

Priority: **Very Likely** = appears most often in BTEUP. **Likely** = good chance. **Possible** = can appear. Each answer follows the exam format: **Definition, Points, Diagram/Table, Conclusion**.

Q1. What is ISO 27001? Explain its structure and the PDCA cycle. VERY LIKELY

Definition / Introduction: ISO/IEC 27001 is the international standard that specifies requirements to establish, implement, maintain and continually improve an Information Security Management System (ISMS). The current edition is ISO/IEC 27001:2022.

Points

- **ISMS:** a risk-based, systematic approach to manage people, processes and technology to protect Confidentiality, Integrity and Availability.
- **Clauses 4 to 10:** context of the organization, leadership, planning (risk assessment and treatment), support, operation, performance evaluation, improvement.
- **Annex A:** 93 controls in four themes (Organizational 37, People 8, Physical 14, Technological 34), recorded in the Statement of Applicability.
- **PDCA:** Plan (scope, policy, risk assessment), Do (implement controls), Check (monitor, internal audit, review), Act (corrective action, improvement).
- **Benefits:** customer trust, legal compliance, fewer incidents, better risk management.

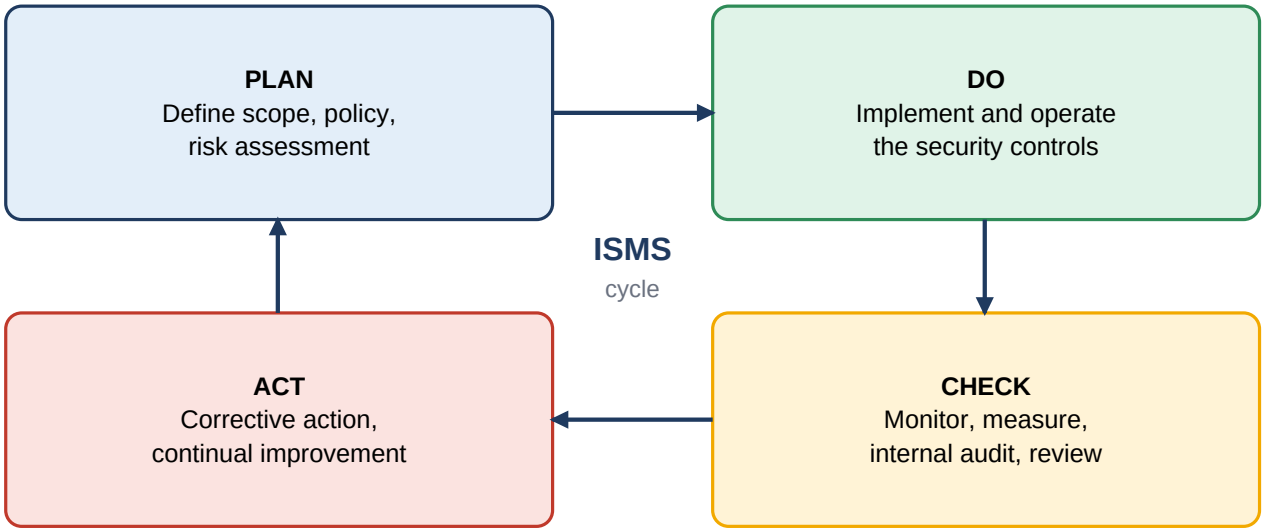


Figure: PDCA cycle of ISMS

Conclusion: ISO 27001 gives organizations a proven framework to manage information security and prove it through certification.

Q2. Explain the Annex A controls and the certification process of ISO 27001.

LIKELY

Definition / Introduction: Annex A of ISO/IEC 27001:2022 is a list of 93 information security controls from which an organization chooses those that address its identified risks.

Points

- **Organizational (A.5):** 37 controls such as policies, roles, asset management, supplier relationships.
- **People (A.6):** 8 controls such as screening, awareness training, remote working.
- **Physical (A.7):** 14 controls such as secure areas, equipment protection, media disposal.
- **Technological (A.8):** 34 controls such as access control, cryptography, logging, malware protection, secure coding.
- **Certification:** Stage 1 (document review), Stage 2 (implementation audit), certificate valid 3 years with yearly surveillance audits, then recertification.

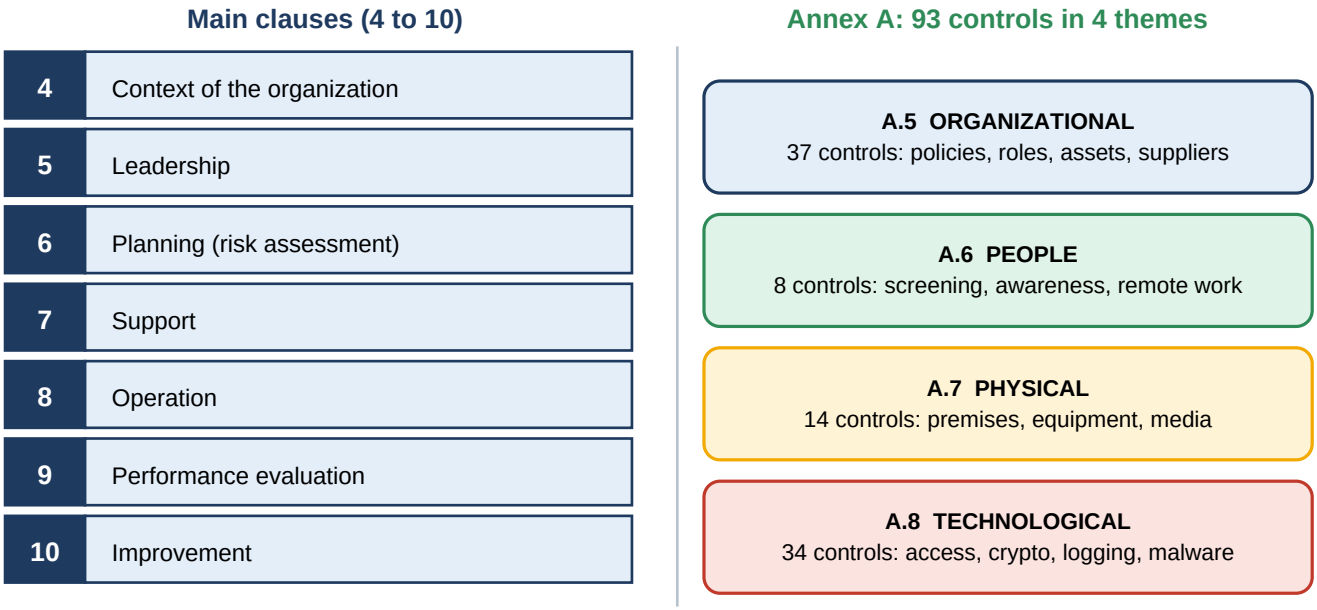


Figure: ISO 27001:2022 clauses and Annex A

Conclusion: Choosing the right controls and getting certified shows customers and regulators that information is managed securely.

Q3. Explain the Information Technology Act, 2000 and its main features. VERY LIKELY

Definition / Introduction: The Information Technology Act, 2000 is the main Indian law dealing with cyber crime and electronic commerce. It was substantially amended by the IT (Amendment) Act, 2008.

Points

- **Legal recognition** of electronic records and digital signatures (Sections 4 and 5), so e-contracts, e-filing and e-governance are valid.
- **Cyber offences and punishments:** hacking, identity theft, cheating by personation, privacy violation, cyber terrorism, obscene content (Sections 65 to 67).
- **Section 43:** compensation to the victim for unauthorized access, data theft or virus damage. **Section 43A:** compensation if a company fails to protect sensitive data.
- **Certifying Authorities** and a Controller license and regulate digital signature certificates.
- **CERT-In (Section 70B)** handles cyber incidents; Section 69 allows lawful interception; Section 70 protects critical information infrastructure.
- It applies to all of India and to offences outside India involving a computer in India. Section 66A was struck down by the Supreme Court in 2015.

Conclusion: The IT Act provides the legal backbone for e-commerce and for punishing cyber crime in India.

Q4. List the cyber offences and their punishments under the IT Act. VERY LIKELY

Definition / Introduction: The IT Act, 2000 (as amended in 2008) defines several cyber offences and prescribes imprisonment and/or fine for each.

Points

- **Section 65:** tampering with computer source documents. **Section 66:** hacking (dishonest or fraudulent act under Section 43).
- **Section 66C:** identity theft. **Section 66D:** cheating by personation. **Section 66E:** violation of privacy.
- **Section 66F:** cyber terrorism, punishable with life imprisonment.
- **Sections 67, 67A, 67B:** obscene, sexually explicit and child abuse material.
- **Section 72:** breach of confidentiality and privacy.

Section	Offence	Punishment
65	Tampering with source documents	3 years / Rs 2 lakh / both
66	Hacking	3 years / Rs 5 lakh / both
66C	Identity theft	3 years and Rs 1 lakh
66D	Cheating by personation	3 years and Rs 1 lakh
66E	Violation of privacy	3 years / Rs 2 lakh / both
66F	Cyber terrorism	Life imprisonment
67	Obscene material	First: 3 years and Rs 5 lakh. Repeat: 5 years and Rs 10 lakh
72	Breach of confidentiality	2 years / Rs 1 lakh / both

Conclusion: These provisions deter cyber crime and give victims a legal remedy.

Q5. What is IPR? Explain the types of IPR. VERY LIKELY

Definition / Introduction: Intellectual Property Rights (IPR) are legal rights given to a person over the creations of the mind, such as inventions, literary and artistic works, designs, symbols and names.

Points

- **Copyright** (Copyright Act, 1957): protects books, music, films and software; life of author + 60 years.
- **Patent** (Patents Act, 1970): protects new inventions; 20 years.
- **Trademark** (Trade Marks Act, 1999): protects brand names and logos; 10 years, renewable.
- **Design** (Designs Act, 2000): protects the look of a product; 10 years + 5.
- **Geographical Indication** (GI Act, 1999): region-based goods such as Darjeeling tea; 10 years, renewable.
- **Trade secret:** secret business information protected by contracts and NDAs.

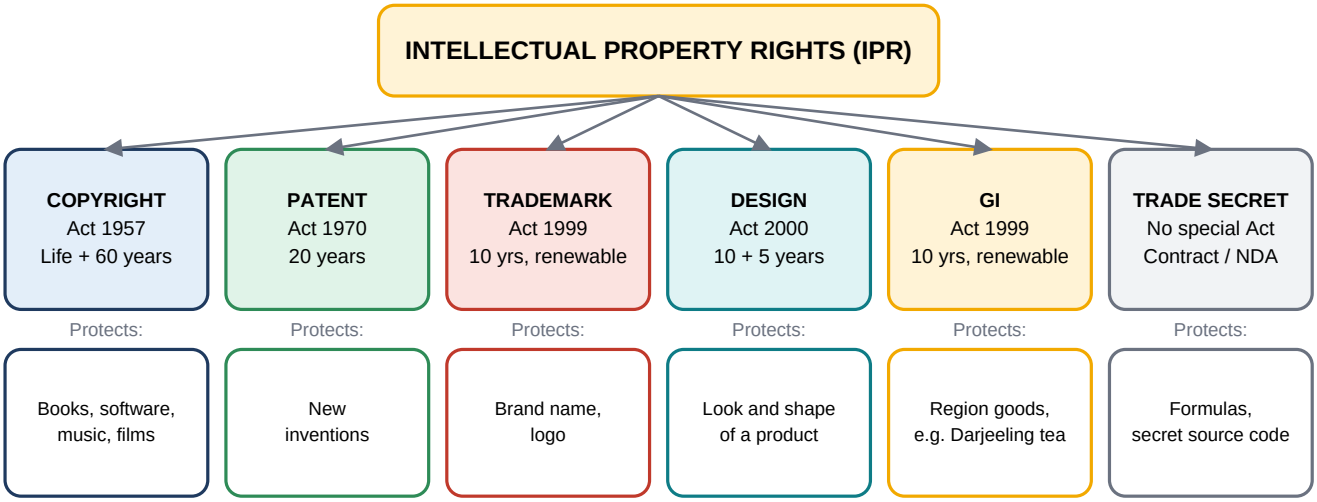


Figure: Types of IPR in India

Conclusion: IPR laws encourage creativity by letting creators control and earn from their work.

Q6. Differentiate between Copyright, Patent and Trademark. LIKELY

Definition / Introduction: Copyright, patent and trademark are three main forms of IPR, protecting different kinds of creations.

Points

- Software is protected by copyright; a computer program per se is not patentable in India (Section 3(k)).

Point	Copyright	Patent	Trademark
Protects	Original works: books, music, software	New inventions	Brand name, logo, slogan
Indian law	Copyright Act, 1957	Patents Act, 1970	Trade Marks Act, 1999
Duration	Life + 60 years	20 years	10 years, renewable
Registration	Automatic (registration optional)	Must be applied for and granted	Registration gives strong rights
Example	A novel, a mobile app	A new engine design	The Nike swoosh

Conclusion: Each IPR protects a different aspect of a creation, and a product may need more than one.

Q7. Explain the security audit procedure. VERY LIKELY

Definition / Introduction: A security audit is a systematic, independent evaluation of an organization's information systems, policies and controls to check compliance with security policy, standards and laws, and to find weaknesses.

Points

- **Planning and scoping:** define objectives, scope, standards and schedule.
- **Information gathering:** policies, network diagrams, asset lists, staff interviews.
- **Risk assessment:** identify assets, threats and vulnerabilities.
- **Testing:** vulnerability scan, penetration test, log and configuration review, physical inspection.
- **Analysis, reporting:** compare with policy, rate risks, prepare report with recommendations.
- **Follow-up:** remediate the gaps and re-audit.

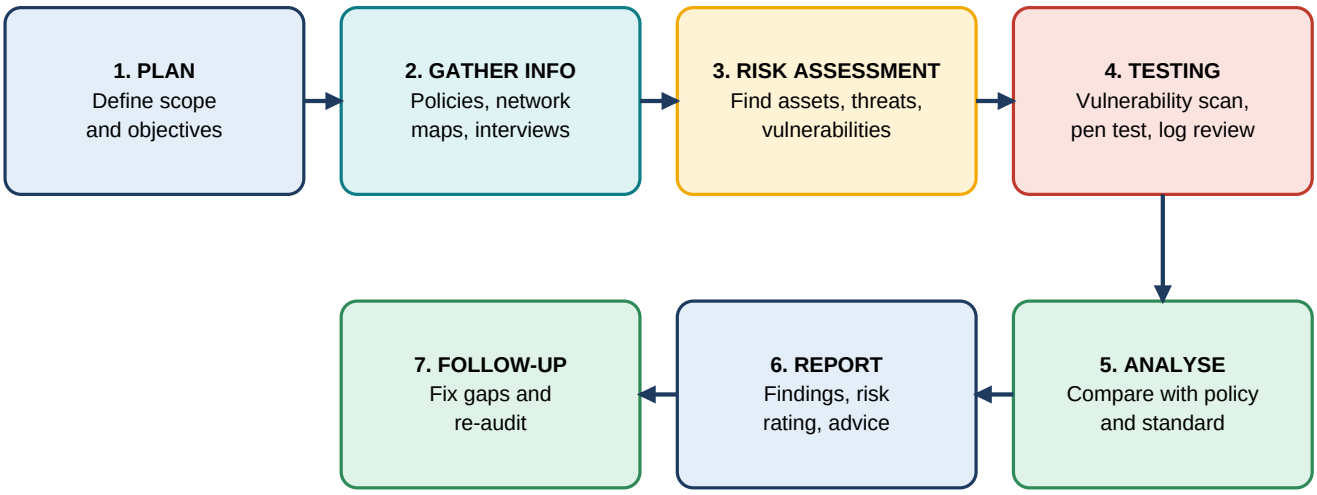


Figure: Security audit procedure

Conclusion: Regular security audits find weaknesses before attackers do and prove compliance to management and regulators.

Q8. Explain the types of security audit. POSSIBLE

Definition / Introduction: Security audits are classified by who performs them and what they check.

Points

- **Internal audit:** performed by the organization's own staff; frequent and low cost, but may be less independent.
- **External audit:** performed by an independent third party or certification body; more objective and needed for certification.
- **Compliance audit:** checks compliance with a standard or law such as ISO 27001 or the IT Act.
- **Technical audit:** tests systems, networks and applications using scanners and penetration tests.

Type	Done by	Main purpose
Internal	Own staff	Self-check, improvement
External	Independent third party	Objective view, certification
Compliance	Internal or external	Standard / law compliance
Technical	Security specialists	Find technical vulnerabilities

Conclusion: Using both internal and external audits gives the best assurance.

Q9. How is a security policy developed? Explain the steps. VERY LIKELY

Definition / Introduction: A security policy is a formal written document, approved by management, that states what must be protected, who is responsible and what rules everyone must follow to keep information secure.

Points

- **Risk assessment:** identify assets, threats and legal requirements.
- **Scope and goals:** decide what the policy covers.
- **Management support:** obtain approval from top management.
- **Draft:** purpose, scope, roles, rules and penalties.
- **Review:** feedback from IT, legal, HR and users.
- **Communicate and train** all employees.
- **Implement and enforce** with technical controls and disciplinary action.
- **Monitor and update** regularly, at least yearly.

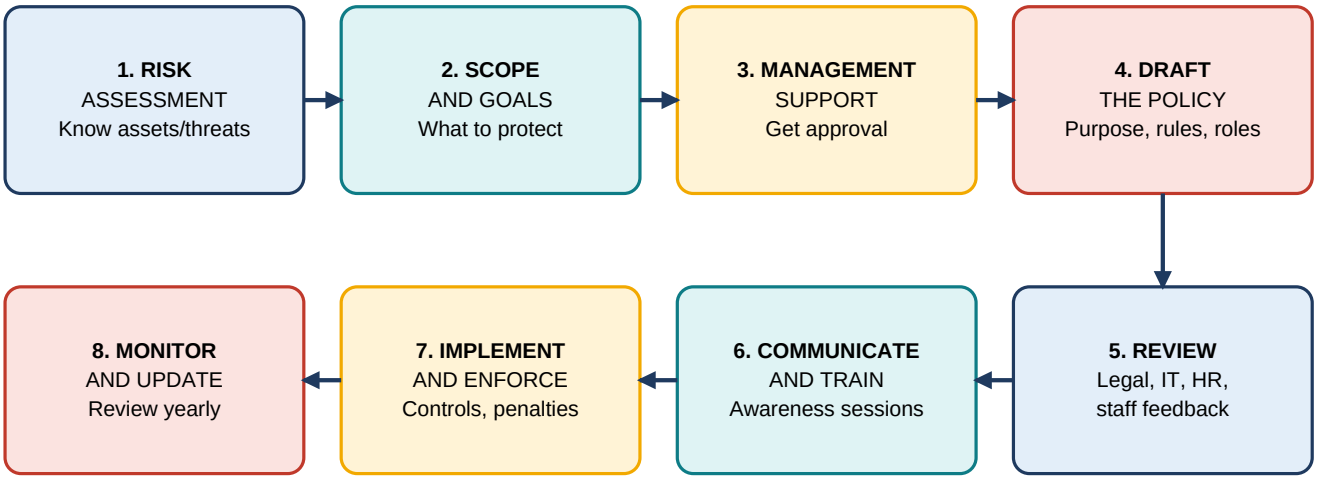


Figure: Steps in developing a security policy

Conclusion: A well-developed, enforced and regularly updated policy is the foundation of an organization's security.

Q10. Explain the different types of security policies. LIKELY

Definition / Introduction: Organizations write separate policies for different areas of security, all supported by standards, procedures and guidelines.

Points

- **Acceptable Use Policy (AUP):** how staff may use computers, email and the Internet.
- **Password policy:** minimum length, complexity, expiry, no sharing.
- **Access control policy:** least privilege and who may access what.
- **Backup policy:** what, how often and how long data is backed up.
- **Incident response policy:** how to report and handle incidents.
- **Remote access / BYOD policy** and **physical security policy**.

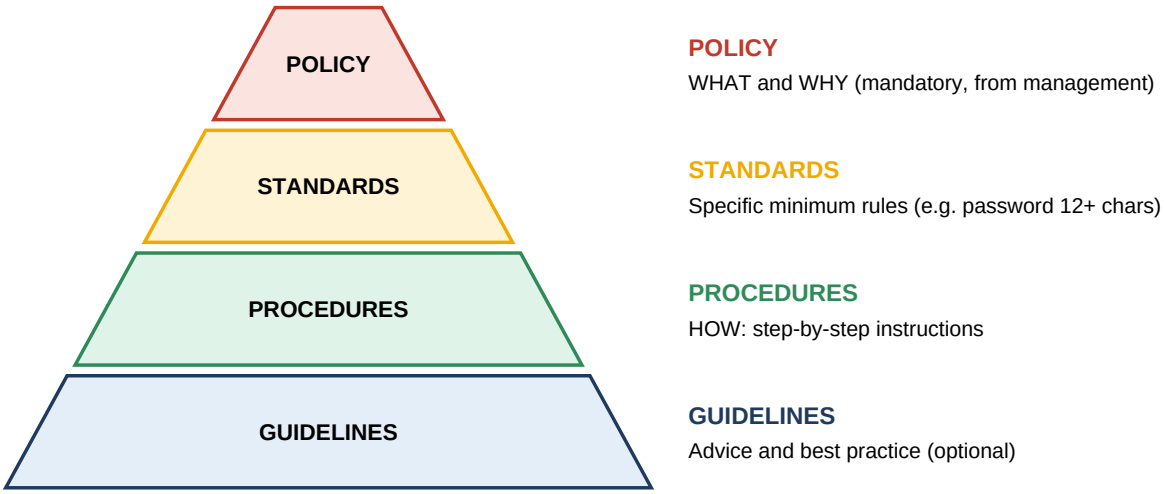


Figure: Policy, standards, procedures, guidelines

Conclusion: Together these policies cover people, technology and processes.

Q11. What is Business Continuity Planning? Explain its steps. VERY LIKELY

Definition / Introduction: Business Continuity Planning (BCP) is the process of creating a plan that ensures critical business functions continue during and after a disaster or disruption.

Points

- **Project initiation:** management approval, team and scope.
- **Business Impact Analysis (BIA):** identify critical processes, allowed downtime and cost of downtime.
- **Risk assessment:** threats such as fire, flood, cyber attack, power failure.
- **Strategy:** backups, alternate site, spare equipment, manual workarounds.
- **Plan development:** write the BCP and DRP with roles and contact lists.
- **Testing and training:** walkthrough, simulation and full drill.
- **Maintenance:** review and update regularly.

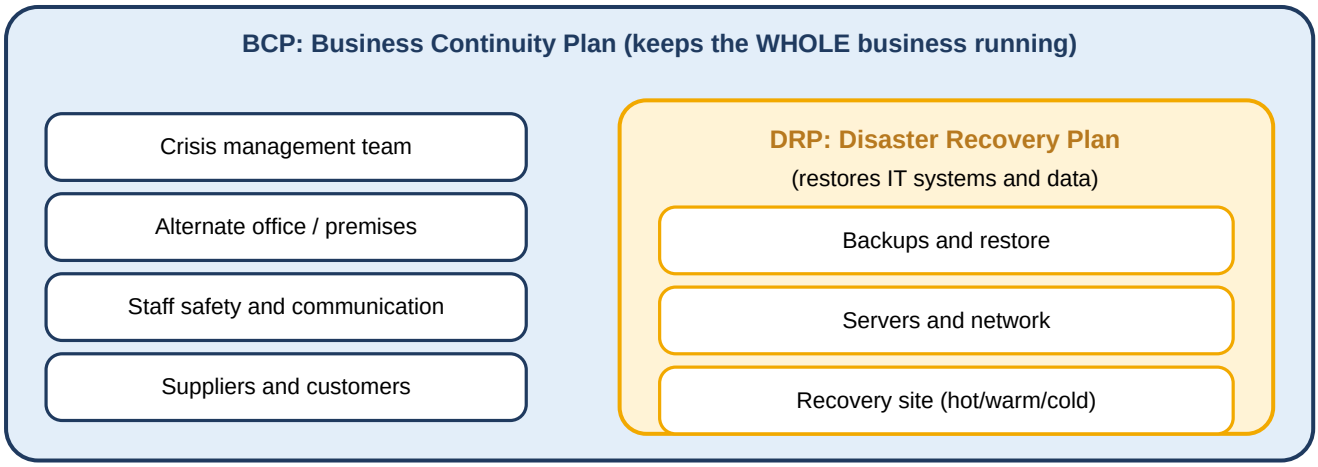


Figure: BCP and DRP

Conclusion: A tested BCP reduces downtime, financial loss and damage to reputation during a disaster.

Q12. What is Disaster Recovery? Explain RTO, RPO and recovery sites. Differentiate BCP and DR.

VERY LIKELY

Definition / Introduction: Disaster Recovery (DR) is the set of policies and procedures to restore IT systems, data and network after a disaster. It is a part of business continuity.

Points

- **RPO:** maximum acceptable data loss measured in time; decides backup frequency.
- **RTO:** maximum time allowed to restore a system; **MTD** is the longest outage the business can survive.
- **Backups:** full, incremental, differential; follow the 3-2-1 rule.
- **Hot site:** fully equipped, live data, recovery in minutes to hours, very costly. **Warm site:** hardware ready, data restored from backup, hours to days. **Cold site:** empty space with power, days to weeks, cheapest.

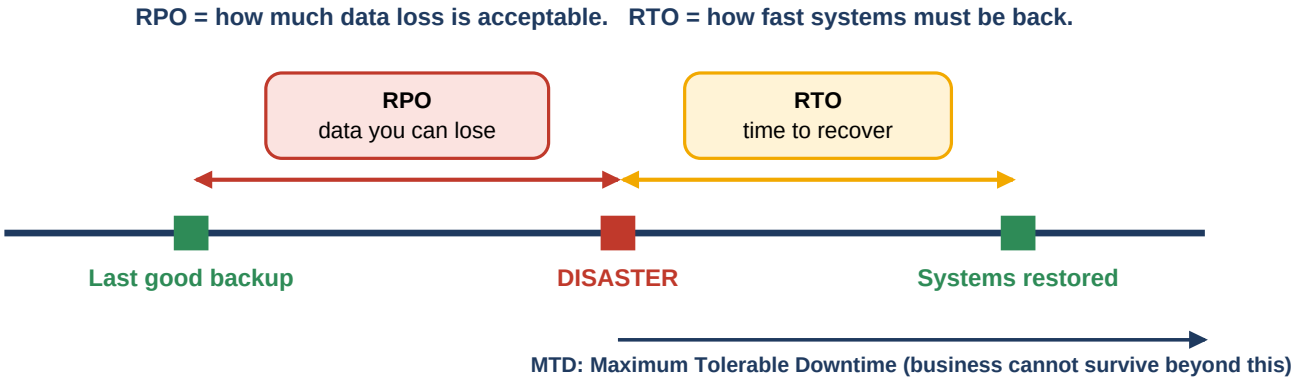


Figure: RPO, RTO and MTD

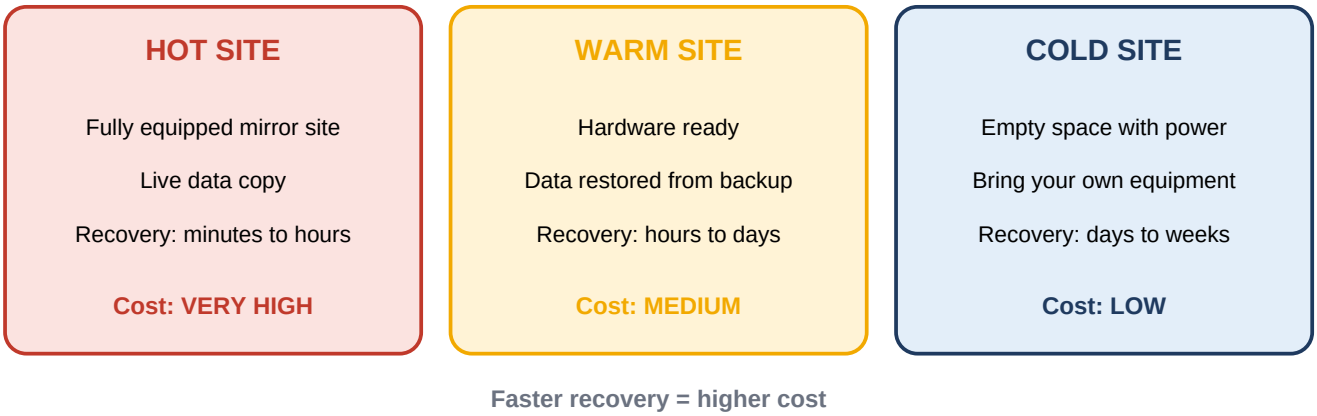


Figure: Hot, warm and cold sites

Point	BCP	DRP
Focus	Whole business	IT systems and data
Scope	Wider	Narrower
Aim	Keep business running	Restore IT after disaster
Timing	Before, during, after	Mainly after

Conclusion: BCP keeps the business alive and DR brings the technology back; together they ensure resilience.

Quick Revision Sheet (read the night before)

Term	Remember this
ISO 27001	ISMS standard. Edition 2022. PDCA. Clauses 4-10
Annex A (2022)	93 controls: Org 37, People 8, Physical 14, Tech 34
Certification	Stage 1, Stage 2, valid 3 years, yearly surveillance
IT Act	2000, amended 2008. Legal value to e-records and digital signatures
Sec 43 / 65 / 66	Compensation / source docs 3 yrs, Rs 2 lakh / hacking 3 yrs, Rs 5 lakh
Sec 66C / 66D / 66E	Identity theft / personation / privacy: 3 years
Sec 66F / 67	Cyber terrorism: life / obscene: 3 yrs + Rs 5 lakh (first)
Sec 66A	Struck down by Supreme Court in 2015
CERT-In	Sec 70B, national cyber incident agency
IPR durations	Copyright life+60, Patent 20, Trademark 10, Design 10+5, GI 10
Software IPR	Copyright protects it. Sec 63 piracy. Sec 3(k): program per se not patentable
Audit steps	Plan, Gather, Risk, Test, Analyse, Report, Follow-up
Policy steps	Risk, Scope, Approval, Draft, Review, Train, Enforce, Update
Policy hierarchy	Policy > Standards > Procedures > Guidelines
BCP vs DR	Whole business vs IT recovery
RPO / RTO / MTD	Data loss limit / recovery time / max outage (RTO < MTD)
Sites	Hot (fast, costly), Warm, Cold (slow, cheap)
Backups / 3-2-1	Full, Incremental, Differential / 3 copies, 2 media, 1 off-site

Memory tricks

Annex A numbers: 37-8-14-34 = Org, People, Physical, Tech (total 93).
IT Act 3-year offences: 65, 66, 66B, 66C, 66D, 66E all up to **3 years**. Fines: 66 = 5 lakh, 65 and 66E = 2 lakh, others = 1 lakh.
IPR years: Copyright **60** after life, Patent **20**, Trademark **10**, Design **10+5**.
RPO = Past (data), RTO = Time (to recover).

Common Mistakes Students Make

- Writing 114 controls for ISO 27001. The current 2022 edition has **93** (114 was the 2013 edition).
- Mixing up **RPO** (data loss) and **RTO** (recovery time).
- Treating BCP and DR as the same. DR is only the IT part of BCP.
- Quoting **Section 66A** as valid. It was struck down in 2015.
- Saying software can be patented directly in India. It is protected by **copyright**.
- Writing a policy as technical steps. A **policy says what and why**; a procedure says how.
- Not drawing diagrams (PDCA, audit flow, RPO/RTO, hot/warm/cold sites).

Self-Test (answer without looking, 5 marks each)

- What is ISO 27001? Explain the PDCA cycle with a diagram.
- Write any four cyber offences under the IT Act with section numbers and punishments.
- Name the types of IPR with their duration.
- Explain the steps of a security audit.
- Differentiate between BCP and DR. What are RTO and RPO?

Self-Test Answers (check after writing)

1. ISO/IEC 27001 is the international standard for an ISMS. PDCA: Plan (scope, policy, risk assessment), Do (implement controls), Check (monitor, audit, review), Act (corrective action, improvement). Draw Figure 1.

2. Example: Sec 66 hacking (3 years / Rs 5 lakh), Sec 66C identity theft (3 years and Rs 1 lakh), Sec 66D cheating by personation (3 years and Rs 1 lakh), Sec 66F cyber terrorism (life imprisonment).

3. Copyright (life + 60 years), Patent (20 years), Trademark (10 years, renewable), Design (10 + 5 years), GI (10 years, renewable), Trade secret (as long as secret).

4. Plan and scope, gather information, risk assessment, testing, analysis, reporting, follow-up (remediation and re-audit). Draw Figure 4.

5. BCP keeps the whole business running; DR restores IT systems and data (a part of BCP). RTO is the maximum time allowed to restore; RPO is the maximum acceptable data loss measured in time.

Done with Unit 5! Information Security is complete.

If you scored 4 out of 5 or more, you are ready for this subject. Next: Mobile App Development.